GOVERNMENT POLYTECHNIC PUNE

(An Autonomous Institute of Government of Maharashtra)

A CASE STUDY REPORT ON

“ICBC Financial Cyberattack (2023)”

A Cyber Security Case Study

Submitted by

Enrollment No.	Name
2406082	Pranav Jagtap

Under the Guidance of

Mrs. S. P. Ambavane

Department of Computer Engineering

GOVERNMENT POLYTECHNIC PUNE

2026–2027

GOVERNMENT POLYTECHNIC PUNE

(An Autonomous Institute of Government of Maharashtra)

Department of Computer Engineering

ACADEMIC YEAR: 2026–27

CERTIFICATE

This is to certify that the case-study entitled **“ICBC Financial Cyberattack (2023)”** is a bonafide case-study carried out by

Enrollment No.	Name
2406082	Pranav Jagtap

of class Third Year in partial fulfilment of the requirement for completion of the course **Cyber Security** of the Diploma in Computer Engineering from Government Polytechnic, Pune. The report has been approved as it satisfies the academic requirements in respect of the case-study work prescribed for the course.

Guide	**H.O.D.**	**Principal**
Mrs. S. P. Ambavane	Mrs. J. R. Hange	Dr. R. K. Patil

ACKNOWLEDGEMENT

I would like to express my sincere gratitude to all those who contributed to the successful completion of this case study on the **“ICBC Financial Cyberattack (2023): A Cyber Security Case Study.”**

Firstly, I would like to extend my heartfelt thanks to my project guide, **Mrs. S. P. Ambavane**, for the constant guidance, valuable suggestions, and continuous support provided throughout the study. This guidance helped me understand the technical working, impact, and security lessons associated with the ICBC ransomware incident.

I would also like to thank the Head of the Department of Computer Engineering for the continuous encouragement and for providing the opportunity to study this important and globally significant cybersecurity incident. This support helped me complete the case study successfully.

Finally, I would like to acknowledge and thank my friends and family for their valuable ideas, discussions, and support during the preparation of this report. Their cooperation and collective effort made this learning experience informative and enriching.

ABSTRACT

The **ICBC Financial Services cyberattack**, disclosed in early November 2023, was one of the most significant cyber incidents ever to strike the global financial system. ICBC Financial Services (ICBCFS) is the United States broker-dealer subsidiary of the Industrial and Commercial Bank of China (ICBC), the world's largest bank by assets. A ransomware attack — attributed by security researchers and news reports to the **LockBit** ransomware-as-a-service group — disrupted the firm's ability to clear and settle United States Treasury securities, the market that underpins global finance.

This case study examines the incident from a technical and cybersecurity perspective: the professionalised ransomware ecosystem of 2022–2023; the role of ICBCFS in Treasury clearing; the vulnerability widely reported as the entry point, the **"Citrix Bleed"** flaw (CVE-2023-4966) in unpatched Citrix NetScaler appliances; the reconstructed attack chain and LockBit's double-extortion model; and the disruption that followed. Unable to access its systems, ICBCFS was temporarily left owing the custodian bank BNY Mellon an amount reported at around **US$9 billion**, and reportedly resorted to delivering settlement details by USB stick while its Chinese parent injected capital so trades could be settled.

Finally, the study highlights the United States legal and regulatory framework, including the new SEC cyber-incident disclosure rules of 2023, the Gramm-Leach-Bliley Act, the NYDFS Cybersecurity Regulation and OFAC guidance on ransom payments; the international takedown of LockBit in February 2024; and the major lessons learned, including prompt patching of internet-facing systems, multi-factor authentication, network segmentation, counterparty and concentration risk, tested recovery and incident response. The ICBC attack demonstrates how a single unpatched device at one intermediary can ripple into the critical infrastructure of the world's most important financial market.

INDEX

Sr. No.	Content	Page No.
1	Introduction to Ransomware and the ICBC Attack	6
2	Background: Ransomware and the Financial Sector	7
3	ICBC, ICBCFS and the Citrix Exposure	8
4	Technical Working of the LockBit Attack	9
5	Ransomware-as-a-Service and Double Extortion	10
6	Disclosure and the Attack Timeline	11
7	Impact on the U.S. Treasury Market and Stakeholders	12
8	Legal and Regulatory Framework (United States)	13
9	Detection, Investigation and Incident Response	14
10	Lessons Learned, Modern Comparison and Conclusion	15
11	References	16

1 · FOUNDATIONS

Introduction to Ransomware and the ICBC Attack

Ransomware is malicious software that encrypts an organisation's data and systems and demands payment for their release. In November 2023 such an attack struck ICBC Financial Services, the United States arm of the world's largest bank, and briefly disrupted trading in United States Treasury securities.

Ransomware versus other malware

Much malware works quietly to spy or steal. Ransomware announces itself: it locks files and servers, then demands a ransom. Modern groups add **double extortion** — they steal data first and threaten to publish it — so even good backups do not remove the pressure to pay. The ICBC incident followed this professionalised, criminal-business pattern.

How ransomware gains entry

Internet-facing remote-access gateways, VPNs, unpatched servers and phishing e-mails all provide openings. In this case, reporting pointed to an **unpatched Citrix remote-access appliance**. The defensive priority is to reduce exposure — patch quickly, enforce multi-factor authentication and segment networks — before an attacker can take advantage.

⚑ **Why the ICBC attack mattered.** ICBC Financial Services clears and settles United States Treasury trades — the market that underpins global finance. A single ransomware intrusion at one intermediary briefly interrupted that function and left the firm reportedly owing its settlement bank around US$9 billion, showing how a routine IT failure can become a systemic concern.

This report is academic and educational: it explains the chain of events at a conceptual level so that incidents of this kind can be understood and prevented, not reproduced.

2 · BACKGROUND

Background: Ransomware and the Financial Sector

The ICBC attack did not happen in isolation. It came at the peak of a wave of financially motivated ransomware against critical organisations, and exploited a vulnerability that was being used against many victims at the same time.

September 2019
The LockBit ransomware operation emerges and grows into one of the most prolific ransomware-as-a-service groups, attacking thousands of organisations worldwide.

2021 – 2023
Ransomware matures into a professional ecosystem of developers, affiliates and initial-access brokers; the financial sector becomes a prime, high-value target.

10 October 2023
Citrix releases a patch for a critical flaw (CVE-2023-4966, later nicknamed “Citrix Bleed”) in its NetScaler remote-access products; mass exploitation soon follows.

Early November 2023
A ransomware attack disrupts ICBC Financial Services in New York, affecting United States Treasury clearing.

Exposure grew because remote-access technology had become essential and criminal ransomware had become a professional industry. In the autumn of 2023 the “Citrix Bleed” flaw was exploited on a mass scale; reported victims in the same period included Boeing, DP World and the law firm Allen & Overy, with researchers counting thousands of still-vulnerable appliances. These were the exact conditions the ICBC attackers exploited.

Sources: CISA / Citrix advisories (2023); TechCrunch, The Register (November 2023); researcher K. Beaumont.

3 · NETWORK THEORY

ICBC, ICBCFS and the Citrix Exposure

To understand the incident, one must understand what ICBC Financial Services does and where its weakness lay. The attack reached a corporate remote-access system; from there it reached the systems used to clear trades.

ICBC and ICBCFS

ICBC (Industrial and Commercial Bank of China) is the world's largest bank by assets. **ICBC Financial Services (ICBCFS)** is its United States broker-dealer subsidiary, based in New York. It acts as an intermediary in the **United States Treasury market**, clearing and settling government-bond and repo trades on behalf of other market participants — a role that connects it directly to the plumbing of global finance.

The Citrix exposure

According to security researchers and news reports, the attackers gained entry through an **unpatched Citrix NetScaler** remote-access appliance vulnerable to **"Citrix Bleed"** (CVE-2023-4966). The flaw lets an attacker hijack a valid user session and bypass passwords and multi-factor authentication. A patch had been available since 10 October 2023, but the device was reportedly not updated in time.

⚠ **A single weak point.** An internet-facing gateway left unpatched gave attackers a foothold that ordinary password and MFA controls could not stop. Effective hardening means patching internet-facing systems urgently, segmenting critical clearing systems from general corporate access, and watching for hijacked sessions.

Sources: Reuters, The Register (November 2023); Wall Street Journal; Citrix (CVE-2023-4966).

4 · TECHNICAL WORKING

Technical Working of the LockBit Attack

At a conceptual level the intrusion ran as a chain of stages: each stage enabled the next, and the attackers were positioned to steal data and halt operations once they had full control.

01 **Exploit the gateway**
Abuse the unpatched Citrix NetScaler (“Citrix Bleed”) to hijack a valid session.

02 **Bypass authentication**
Reuse the stolen session token to log in without a password or MFA code.

03 **Establish a foothold**
Run remote-access tools on the first reachable system inside the network.

04 **Persistence**
Create accounts or tasks so access survives a reboot or password change.

05 **Credential theft**
Harvest administrator credentials to widen control across servers.

06 **Lateral movement**
Move from host to host across the corporate IT network.

07 **Exfiltration**
Copy sensitive data out before any alarm is raised (double-extortion leverage).

08 **Inhibit recovery**
Disable security tools and delete or encrypt backups and shadow copies.

09 **Encrypt & extort**
Encrypt systems, halt operations and demand a ransom for the decryption key.

Conceptual lifecycle: Exploit Gateway → Bypass Auth → Foothold → Persist → Steal Credentials → Move → Exfiltrate → Inhibit Recovery → Encrypt. Reconstructed from LockBit’s documented behaviour and “Citrix Bleed” exploitation; ICBC published no forensic report, so the stages are inferred and described conceptually for academic purposes.

5 · EXTORTION MODEL

Ransomware-as-a-Service and Double Extortion

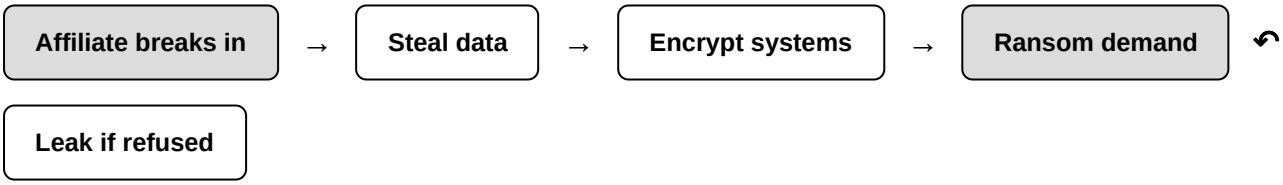
LockBit was not a lone hacker but a criminal business. Understanding its ransomware-as-a-service model explains both how the attack happened and why the damage went beyond encryption alone.

Part A · Ransomware-as-a-Service

A core LockBit team built and maintained the ransomware, the negotiation portal and the leak site, while **affiliates** carried out the intrusions and shared the ransom. This division of labour let many criminals launch attacks at once. Active since 2019, LockBit became one of the most prolific ransomware operations in the world, with thousands of claimed victims.

Part B · Double extortion

Before encrypting, affiliates copy data out. Victims then face two threats: locked systems and the public release of stolen information. In the ICBC case a LockBit representative **claimed the bank paid a ransom** (“deal closed”); this was reported by news agencies but **could not be independently verified**, and ICBC did not confirm it.



Conceptual extortion flow: data is stolen before encryption, so refusing to pay risks a public leak; good backups can restore systems but cannot “un-steal” data.

6 · INCIDENT DYNAMICS

Disclosure and the Attack Timeline

The incident unfolded over a few days in November 2023, from the first disruption to the capital injection that let trades settle — and reached a wider conclusion when LockBit itself was dismantled months later.

8–9 Nov 2023
A ransomware attack strikes ICBC Financial Services; it disconnects affected systems and reports the incident to law enforcement.

9–10 Nov 2023
Treasury clearing is disrupted; ICBCFS reportedly sends settlement details by USB stick, and is left temporarily owing BNY Mellon around US$9 billion.

10–13 Nov 2023
ICBC’s parent injects capital so the unit can settle trades and repay BNY Mellon; researchers and a reported U.S. Treasury e-mail attribute the attack to LockBit via “Citrix Bleed”.

13 Nov 2023
A LockBit representative claims ICBC paid a ransom; the claim is unverified and ICBC does not confirm it.

20 Feb 2024
“Operation Cronos” — the UK NCA with the FBI and Europol — seizes LockBit’s infrastructure and source code and makes arrests.

Sources: Reuters, Bloomberg, Finextra (November 2023); UK National Crime Agency (February 2024).

7 · CONSEQUENCES

Impact on the U.S. Treasury Market and Stakeholders

The impact fell on market operations and confidence rather than on any direct loss of customer funds. Reports described the overall market disruption as limited, but the episode exposed how dependent the system is on a few intermediaries.

~US$9bn

REPORTED AMOUNT ICBCFS TEMPORARILY OWED BNY MELLON FOR UNSETTLED TRADES

Stakeholder	Observed consequence	Resilience lesson
ICBC Financial Services	Systems disconnected; clearing halted; large settlement obligation	Patch and segment critical systems
BNY Mellon	Left as counterparty to ~US$9bn of unsettled trades; manual settlement	Manage counterparty and concentration risk
U.S. Treasury market	Some trades rerouted; questions over market resilience	Build resilience into market plumbing
Other participants	Unsettled trades affected short-term liquidity	Plan for an intermediary outage

Unable to access its own systems, ICBCFS reportedly delivered settlement details on a **USB stick by messenger**, and its Chinese parent injected capital so the unit could settle trades and repay BNY Mellon, the sole settlement agent for Treasuries. Analysts could not say for certain whether the disruption contributed to a weak 30-year bond auction that week. Dollar figures are drawn from news reports and should be treated as reported estimates, not audited totals.

Sources: Reuters, Bloomberg (November 2023); Financial Times; PYMNTS.

8 · LEGAL FRAMEWORK

Legal and Regulatory Framework (United States)

The attack struck a United States regulated broker-dealer just as the country was tightening its cyber-incident and disclosure rules, and it illustrated how several overlapping regimes apply to one event.

4 days

SEC WINDOW TO DISCLOSE A MATERIAL CYBER INCIDENT ON FORM 8-K · RULES EFFECTIVE DECEMBER 2023

Provision	What it covers	Relevance
SEC cyber disclosure rules (2023)	Material incidents reported on Form 8-K (Item 1.05)	Public companies must disclose promptly
Gramm-Leach-Bliley Act	Safeguards Rule: protect customer financial data	Financial firms owe a duty of security
NYDFS 23 NYCRR Part 500	Cybersecurity program, MFA and reporting for NY entities	A NY broker-dealer must meet strict rules
OFAC ransomware guidance	Sanctions risk in facilitating ransom payments	Paying a ransom can carry legal risk

Because ICBCFS is a New-York-based broker-dealer, it falls under federal securities regulation, the NYDFS Cybersecurity Regulation and financial-privacy law. The United States Treasury and market bodies also monitor the resilience of Treasury-market infrastructure. OFAC has warned that paying ransoms can breach sanctions where the recipient is a designated group, which is one reason ransom decisions are legally sensitive.

Sources: U.S. SEC (2023 rules); FTC Safeguards Rule; NYDFS Part 500; U.S. Treasury / OFAC advisories.

9 · DEFENSIVE PRACTICE

Detection, Investigation and Incident Response

ICBC’s response contained the damage and kept customer funds safe, but public information suggests the firm was reacting to encryption rather than catching the intrusion early.

Detect

The attack became evident when systems were encrypted and clearing stopped. Catching a session hijack or data theft earlier would need continuous monitoring of the remote-access gateway and of unusual movement inside the network.

Contain

ICBCFS **disconnected affected systems** and an electronic settlement platform to stop the spread, and reported the incident to law enforcement — limiting the blast radius at the cost of temporary manual working.

Recover

Trades were settled manually (reportedly via USB), the parent bank **injected capital** so obligations could be met, systems were rebuilt, and an external cyber review was sought.

✓ **Controls connect to behaviour.** Prompt patching would likely have prevented entry; monitoring finds intrusions early; isolation limits reach; and capital, backups and a tested plan enable recovery. The coordinated international takedown of LockBit in 2024 showed that law enforcement, not ransom payment, is the durable answer.

Sources: Reuters, Finextra, PYMNTS (November 2023); NIST SP 800-61 Rev. 2.

10 · SYNTHESIS

Lessons Learned, Modern Comparison and Conclusion

Lessons learned

The ICBC attack reinforces enduring security principles: **urgent patching** of internet-facing systems, **phishing-resistant MFA and session monitoring**, **network segmentation** of critical clearing systems, **exfiltration monitoring**, management of **counterparty and concentration risk**, **immutable, tested backups** and a **rehearsed incident-response and continuity plan**. Each maps directly to a weakness the incident exposed.

Feature	ICBC (2023)	Recommended today
Patching	Internet-facing Citrix device unpatched	Urgent patching of exposed systems
Authentication	Session hijack bypassed MFA	Session monitoring; revoke stale tokens
Segmentation	Clearing systems reachable from IT	Isolate critical market systems
Counterparty risk	~US$9bn exposure to one agent	Limit and plan for concentration risk
Recovery	Manual, capital-dependent settlement	Immutable backups; tested continuity

Conclusion

The ICBC Financial Services cyberattack of 2023 was serious yet, in important respects, contained. A ransomware group — attributed to LockBit — exploited a widely known, unpatched vulnerability to disrupt a single broker-dealer, and in doing so briefly interrupted the clearing of United States Treasury securities and left the firm reportedly owing billions to its settlement bank. Yet the market impact was limited, customer funds were protected, and trades were settled within days. Its enduring lesson is that in a deeply interconnected financial system, a single unpatched device at one intermediary can ripple into critical infrastructure — so patching, segmentation and resilience are not just IT housekeeping but matters of financial stability.

References: Reuters · WSJ · The Register · Citrix / CISA · UK NCA · SEC. (Full list on the following page.)

11 · REFERENCES

References

The following reliable news, official and industry sources were used in preparing this case study.

[1] Reuters (9–13 November 2023). “ICBC’s U.S. unit hit by ransomware attack” and “Gang says ICBC paid ransom over hack that disrupted US Treasury market.”

[2] Bloomberg (November 2023). Reporting on ICBC settling trades via USB and the ~US$9 billion owed to BNY Mellon.

[3] The Register (10 November 2023). “ICBC hit by ransomware; LockBit suspected.”

[4] Wall Street Journal (November 2023). Report of a U.S. Treasury e-mail naming LockBit and the Citrix Bleed flaw.

[5] Citrix / CISA (October–November 2023). Advisories on CVE-2023-4966 (“Citrix Bleed”) in NetScaler ADC and Gateway.

[6] TechCrunch (14 November 2023). “Citrix Bleed: the critical bug behind a wave of mass cyberattacks.”

[7] U.S. National Crime Agency (NCA), FBI and Europol (20 February 2024). “Operation Cronos” disruption of LockBit.

[8] U.S. Securities and Exchange Commission (2023). Final rules on cybersecurity risk management and incident disclosure (Form 8-K, Item 1.05); NIST SP 800-61 Rev. 2, Computer Security Incident Handling Guide.

All facts in this report are drawn from the public sources listed above. ICBC did not publish a forensic report, so the technical attack chain is a reconstruction based on LockBit’s documented behaviour and reported details, and is stated as such; attacker claims (including the claim that a ransom was paid) are identified as unverified claims, and financial figures are reported estimates. The “2023 vs recommended today” comparison is present-day analysis.